

Human Resources Security

Dr. Ruba Alomari

**MIT5600G – Security Policies and Risk
Management**

References

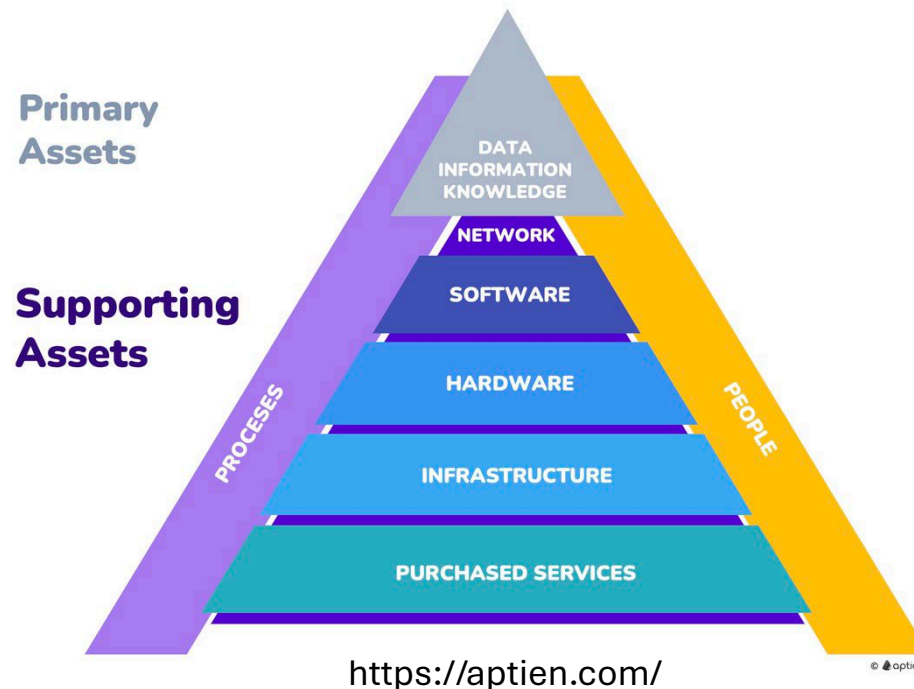
- The material in these lecture notes is based on the course textbook:

Omar Santos, “Developing Cybersecurity Programs and Policies in an AI-Driven World”, 4th Editions, 2024. Pearson IT Certification. ISBN-10: 0-13-532422-X, ISBN-13: 978-0-13-532422-6

- Unless otherwise specified, all the figures, tables, policy examples, and content is from the textbook.
- All material is the copyright of the author and publisher Copyright 2019 Pearson Education, Inc.

Recall – Last Week – What Is an Information Asset?

- A definable piece of information, stored in any manner, that is recognized as **having value to the organization.**
- Information assets include raw, mined, developed, and purchased data.



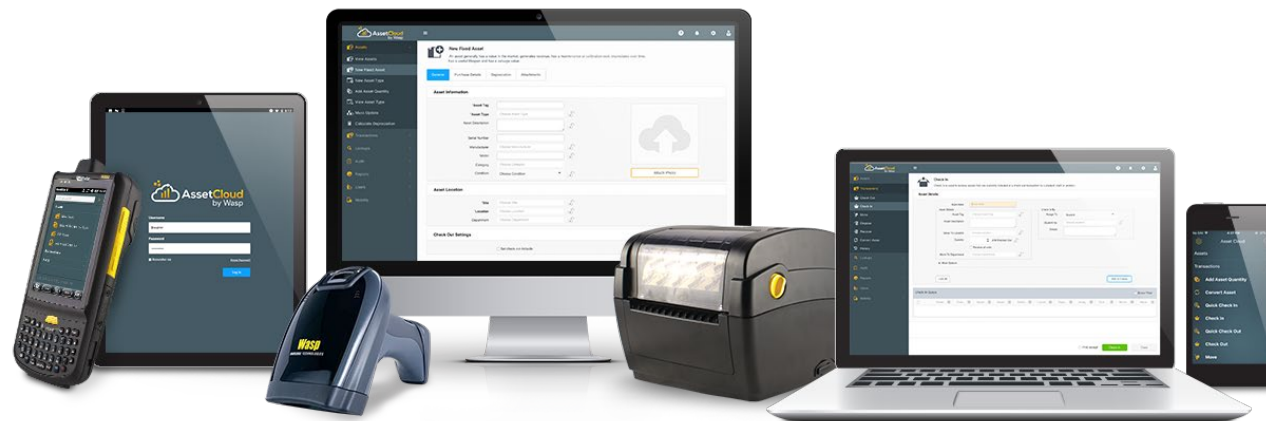
Recall – Last Week – Why Classify Information?

- **Information Classification:** The organization of information assets according to their sensitivity to disclosure.
 - The outcome of the classification process is instructions on:
 - ~~who~~ who can access the asset,
 - ~~how~~ how the asset is to be used,
 - ~~what~~ what security measures need to be in place,
 - and ultimately, the method by which the asset should be destroyed or disposed of.
-

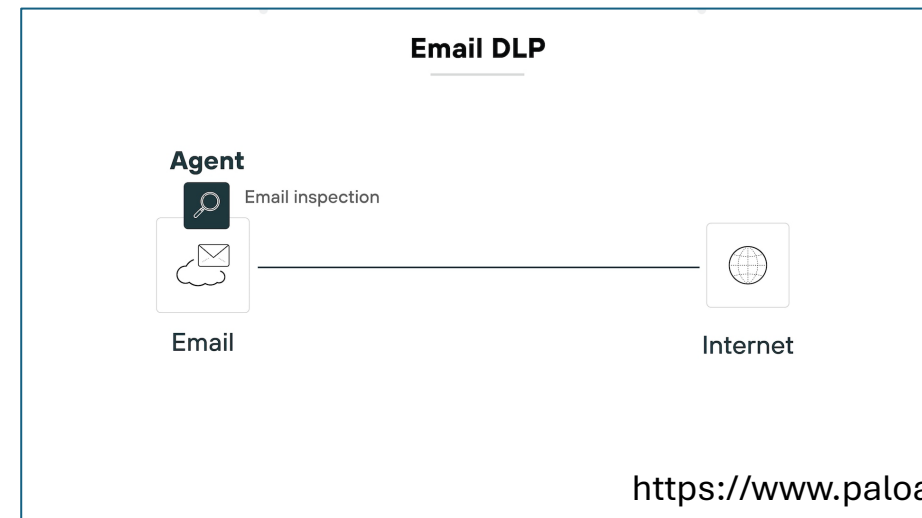
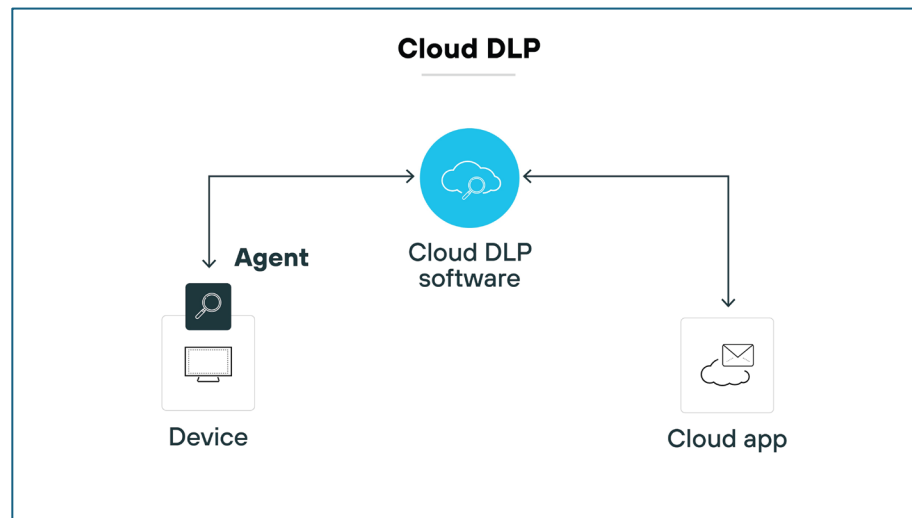
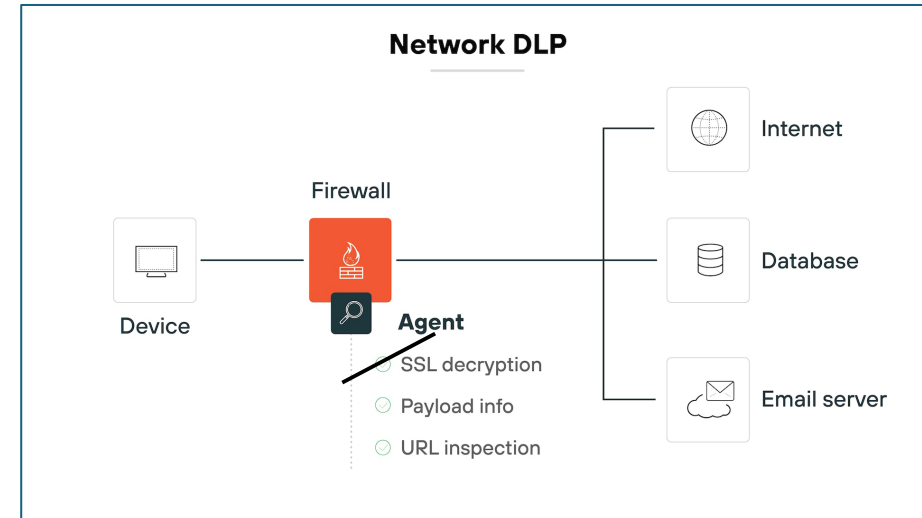
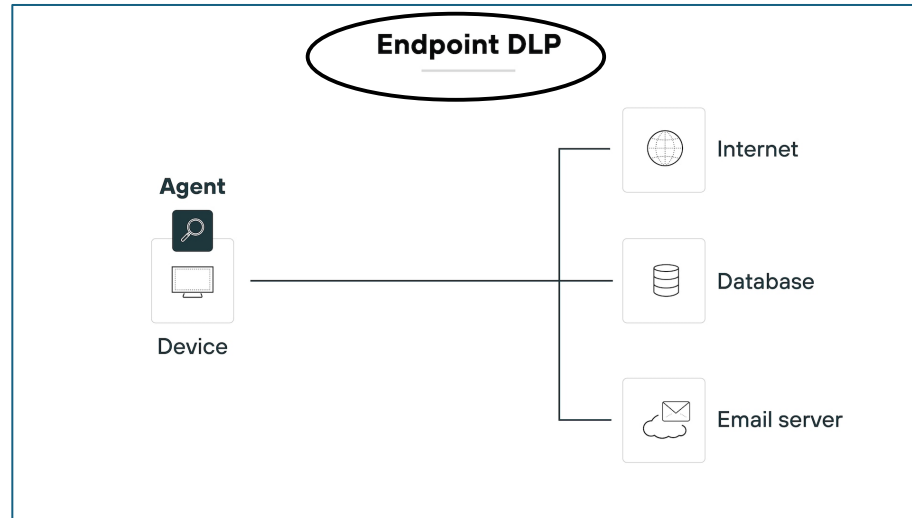


Recall – Last Week – Why an Inventory Is Necessary?

- An information systems inventory is necessary because without it, it will be very challenging to efficiently and accurately keep track of:
 1. All the items that need to be secured
 2. All the elements that can introduce risk to the organization.
- Creating a comprehensive inventory of information systems is a **major task**
- Company assets should be accounted for **at all times**



Recall – Last Week – DLP Placement



<https://www.paloaltonetworks.com/>

Topics

- Employee Life Cycle
- Employee Agreements
- Security Education and Training Awareness (SETA)

Topics

- Employee Life Cycle
- Employee Agreements
- Security Education and Training Awareness (SETA)

The Employee Lifecycle

- Represents stages in the employee's career
- Lifecycle models can vary but most include the following stages
 1. Recruitment
 2. Onboarding
 3. User provisioning
 4. Orientation
 5. Career development
 6. Termination
 7. Off-boarding

Cybersecurity Analyst

Decisive Group | Ottawa, ON | Remote

[Apply now](#) [Bookmark](#) [Share](#)

Summary

The primary objective of the Cybersecurity Analyst is to monitor security alerts for potential malicious activity in the Security Information and Event Management (SIEM) environment. These roles are in an environment that operates 24x7x365 over 3 shifts (day, evening, and night). Each team member completing day, evening, and overnight shifts with one full paid week off per full rotation!

Principal Duties

- Monitor security alerts of potentially malicious activity detected by security systems such as Firewalls, Intrusion Detection and Prevention Systems (NIDS/NIPS, HIDS/HIPS, WIDS), Log Monitoring, File Integrity Monitoring and SIEM;
- Determine and classify the severity of alerts and assess potential impacts;
- Report and investigate potential security incidents;
- Provide recommendations to clients for containment and eradication of threats;
- Provide Incident Response (IR) support when analysis confirms an actionable incident;
- Update security operations processes and procedures;
- Conduct research, consult with colleagues and training to maintain awareness of trends in new security threats, technologies, and regulations;
- Assist in IT security investigations, exercises and tests;
- Other tasks and responsibilities as assigned.

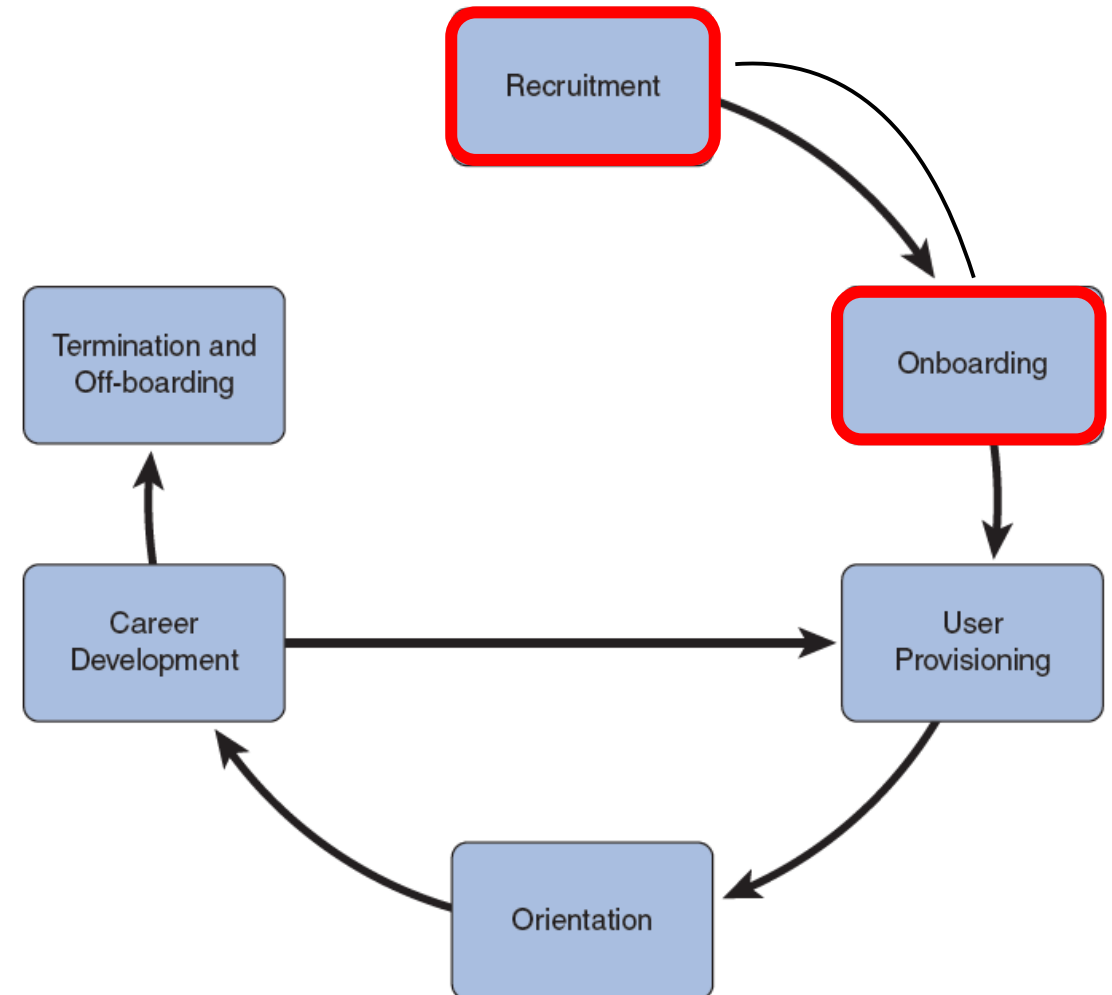
Training/Experience

- **Must possess or be able to attain Secret Security Clearance;**
- Analytical and problem-solving skills;
- Ability to manage multiple tasks;

<https://ca.indeed.com/>

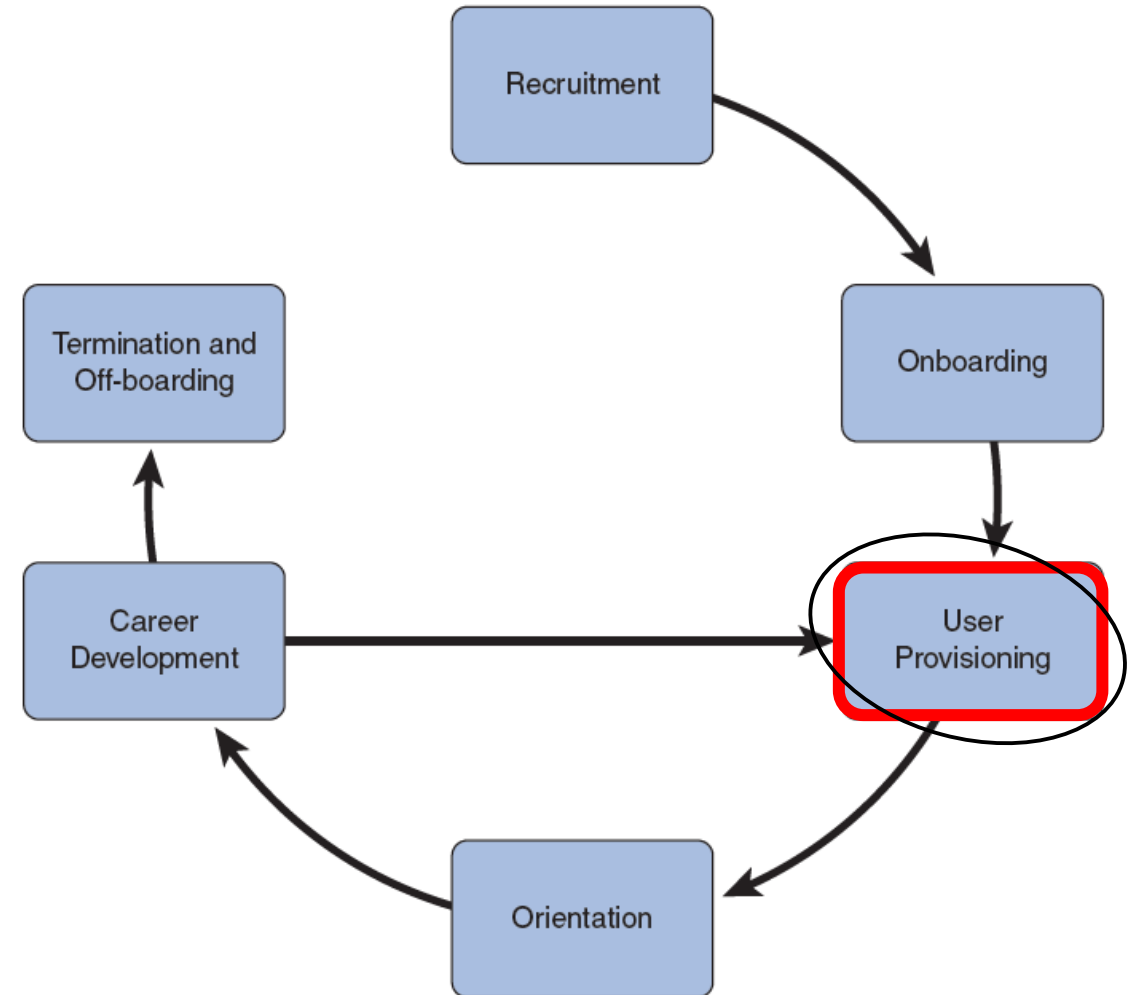
The Employee Lifecycle Stages /1

- **Recruitment**: The processes leading up to and including the hiring of a new employee.
- **Onboarding**: The employee is added to the organization's payroll and benefits systems.



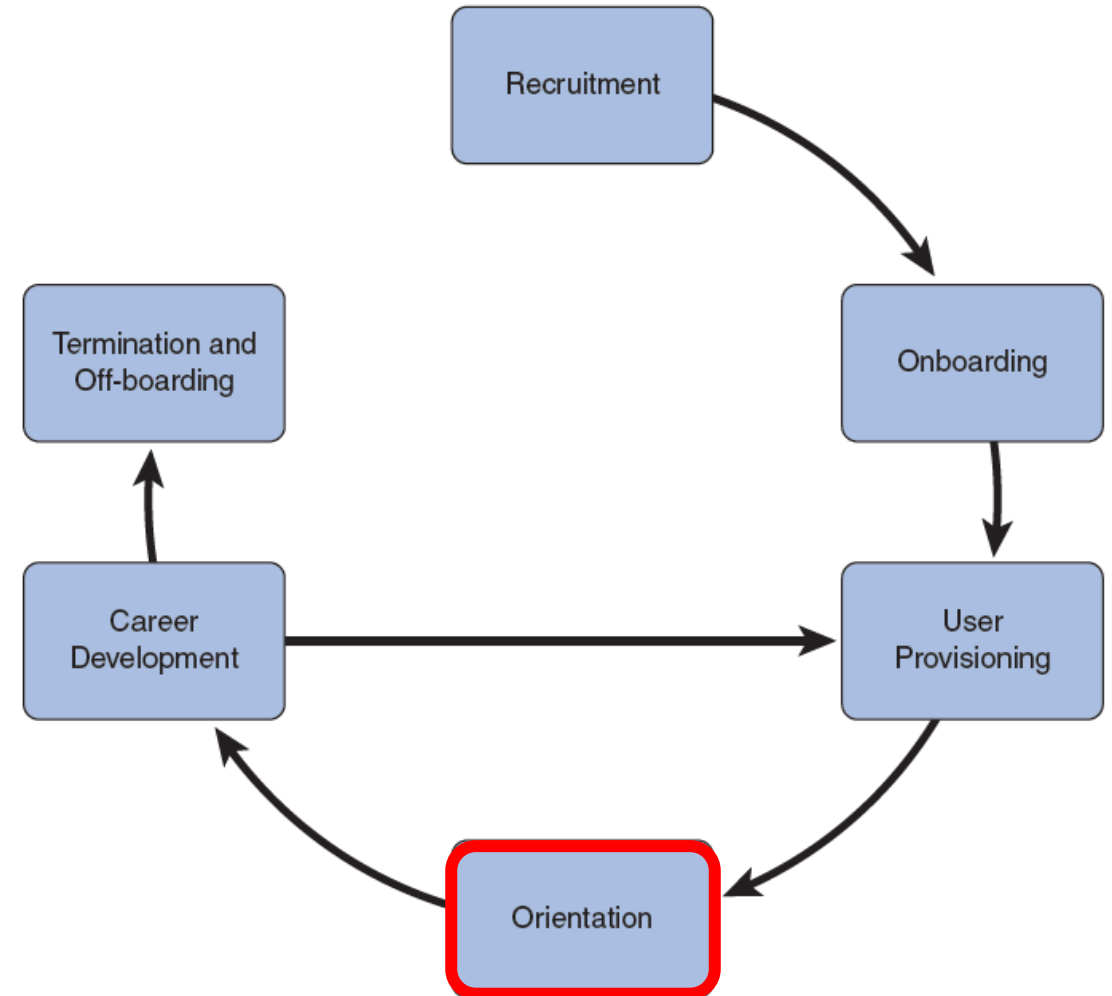
The Employee Lifecycle Stages /2

- ~~User provisioning~~: The employee is assigned equipment as well as physical and technical access permissions.
- Also invoked whenever there is a change in the employee's position or the level of access required.



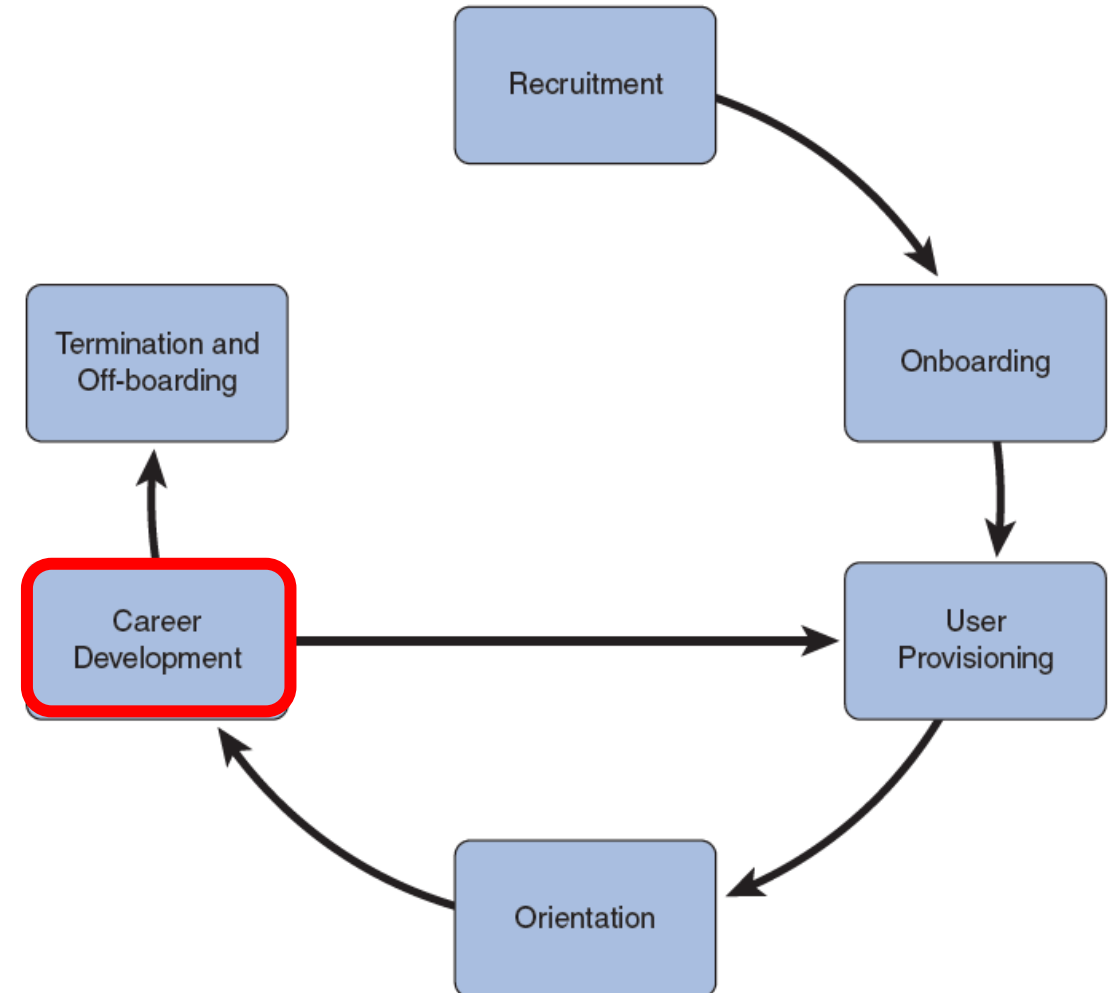
The Employee Lifecycle Stages /3

- **Orientation:** The employee settles into the job, integrates with the corporate culture, familiarizes themselves with co-workers and management, and establishes their role within the organization.



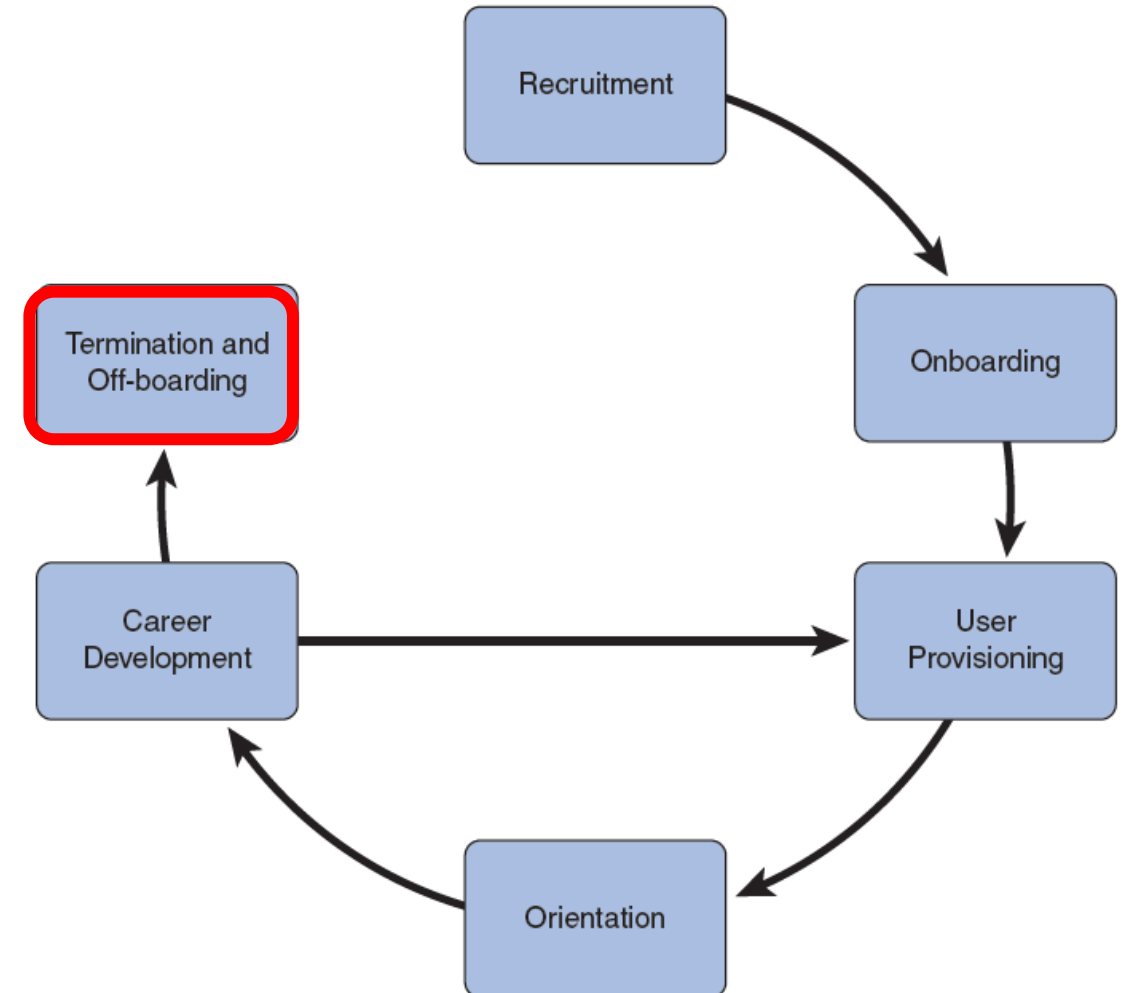
The Employee Lifecycle Stages /4

- **Career development:** The employee matures in their role in the organization.
- Professional development frequently means a change in roles and responsibilities.



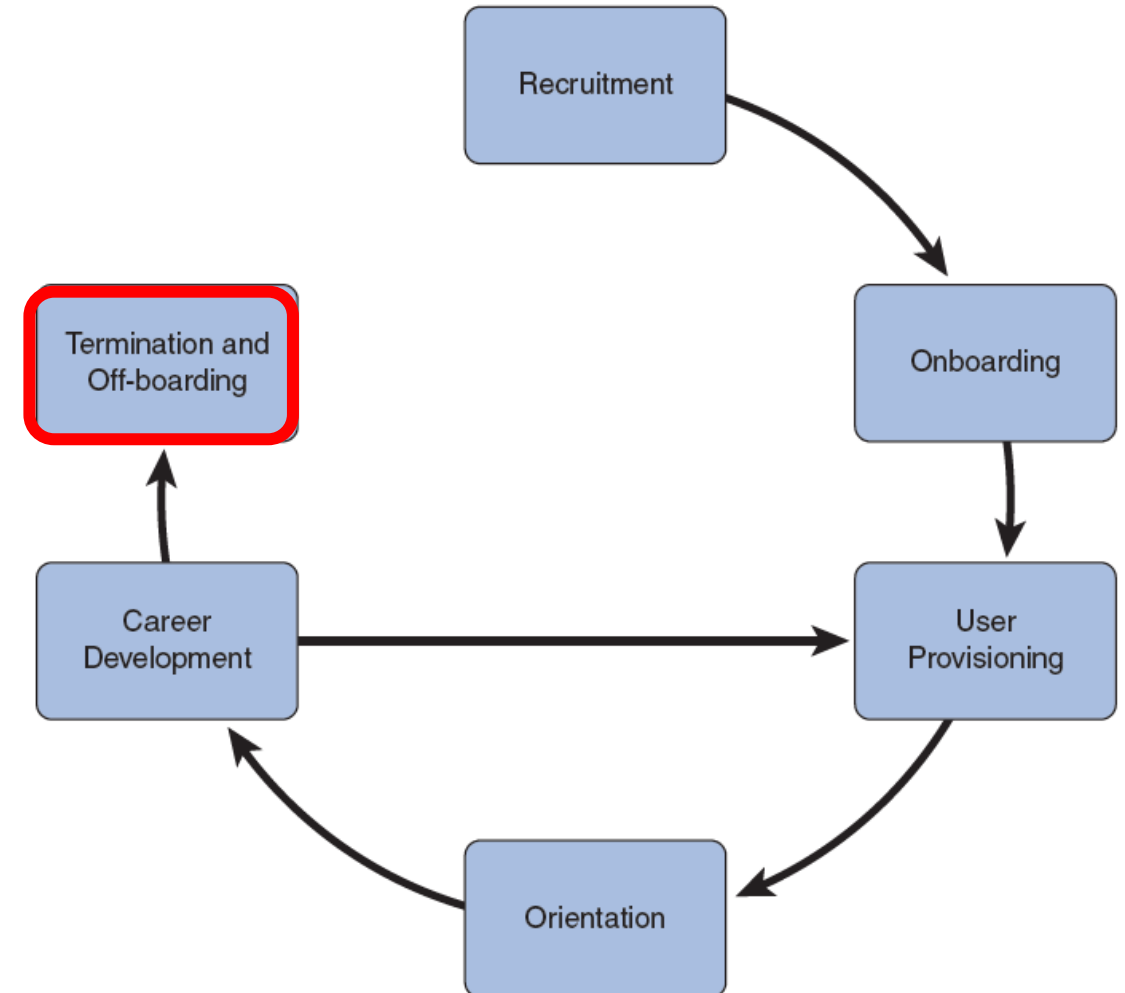
The Employee Lifecycle Stages /5

- **Termination:** The employee leaves the organization.
- Somewhat dependent on whether the departure is the result of **resignation**, **firing**, or **retirement**.
- Includes:
 - Removing the employee from the payroll and benefits system,
 - recovering information assets,
 - and deleting or disabling user accounts and access permissions.



The Employee Lifecycle Stages /6

- **Off-boarding:** The process for transitioning employees out of an organization.
- This includes documenting the separation or termination details, tasks and responsibilities prior to departure, knowledge transfer, an exit interview, the deletion of all user credentials and any other access the user had.



What Does Recruitment Have to Do with Security?

- The recruitment stage includes:
 - developing and publishing job descriptions,
 - collecting and assessing candidate data,
 - interviewing,
 - conducting background checks,
 - and either making an offer or rejecting a candidate.
- A significant flow of information occurs during the recruitment stage.

HELP WANTED - Chief Information Security Officer (CISO)

Seeking a highly motivated security professional with: Created by ChatGPT

- CISSP, CISM, CRISC, CEH, CCISO, OSCP, Security+, Network+, and any certifications we forgot to list.
- Minimum **20 years of cybersecurity experience**.
- Experience with cloud security, AI security, OT security, IoT security, quantum-resistant cryptography, and technologies that have not yet been invented.
- Master's degree required; PhD preferred.
- Must be available **24/7/365**.
- Must have excellent communication skills and be capable of explaining cybersecurity to executives who believe antivirus is sufficient protection.

Job Responsibilities

- Protect the organization from all cyber threats.
- Guarantee zero breaches.
- Secure legacy systems running Windows Server 2003.
- Secure cloud systems that nobody documented.
- Secure shadow IT that nobody admits exists.
- Approve every security request within one hour.
- Complete all compliance audits with no budget.
- Deliver security awareness training to employees who click every phishing email.

Authority

- Responsible for all organizational security.
- Accountable for all security outcomes.
- Budget approval requires signatures from seven committees.
- No authority to enforce security controls.

Rewards and Risks of Online Employment Ads

- A company can reach a wide audience
- However, a company can publish an ad that gives too much information:
 - About the network infrastructure, which allows a hacker to footprint the internal network easily and stealthily
 - About the company itself, inviting social engineering attacks
- **Question:** How to solve this issue?

🔒 ⚠️ Example of a Faulty Job Posting ⚠️ 🔒

*This is a mock post to demonstrate what **not** to do.*

Created by ChatGPT

Job Title: Senior Network Administrator

Company: SecureNet Global

Location: Downtown Toronto – 7th Floor, Suite 701

Salary: \$105,000 - \$120,000

Contact: Directly reach our CIO, John_Doe@sngcorp.com (he responds fast!)

About Us: SecureNet Global is a rapidly growing cybersecurity company. We recently upgraded our internal network to a hybrid architecture using Cisco ASA 5506-X firewalls, with dual Fortinet VPN concentrators (currently using firmware v6.2.3). Our Active Directory domain controller (DC01.sng.local) was moved to the cloud last month (AWS EC2, Toronto zone), and all DNS zones are now integrated with our internal DHCP scope range of 10.0.35.0/24.

Our email system is hosted internally on Exchange 2016 (soon migrating to O365). We use SolarWinds Orion for network monitoring (yes, fully patched after the breach!), and our default admin credentials are managed through KeePass (version 2.48) on a shared drive.

Job Description:

As a Senior Network Admin, you'll:

- Monitor and manage our Cisco ASA firewalls and layer 3 switches (access passwords provided during onboarding).
- Oversee our internal file shares (\sng-fs01\HR\ and \sng-fs01\Projects\Classified).
- Train staff to use PowerShell scripts for unlocking AD accounts (script templates in \admin\scripts).
- Report monthly security logs directly to our CTO (currently on sabbatical—email his backup: itdept@sngcorp.com).

Perks:

- Access to our internal IT lab (door PIN: 1987, reset monthly).
- Fully remote access via OpenVPN (port forwarded at IP 192.168.1.50).
- Company laptop preconfigured with root SSH access.

Online Job Description Postings

- Consider having two versions of a job description.
 - **Version A** is posted and/or published and has enough information to attract the attention and interest of a potential employee.
 - **Version B** is more detailed and is posted internally and/or shared with candidates who have made the “first cut.”

✓ Secure & Professional Job Posting ✓

Job Title: Senior Network Administrator

Company: SecureNet Global

Location: Toronto, ON

Salary Range: Competitive, commensurate with experience

Apply via: careers@sngcorp.com

Created by ChatGPT

About SecureNet Global: SecureNet Global is a fast-growing technology company focused on cybersecurity and digital infrastructure solutions. Our team supports a modern IT environment that leverages cloud services and on-prem systems to deliver resilient and secure solutions to our clients.

Position Overview: We're looking for a seasoned Senior Network Administrator to join our Infrastructure & Security team. In this role, you'll play a critical part in managing and securing enterprise networks, supporting incident response, and optimizing system availability.

Key Responsibilities:

- Maintain and monitor enterprise-grade firewalls, switches, and VPN infrastructure.
- Administer directory services and implement access control policies.
- Work with the cybersecurity team on hardening systems and ensuring patch compliance.
- Lead network segmentation and monitoring initiatives to improve security posture.
- Document infrastructure procedures and maintain secure configuration baselines.

Qualifications:

- 5+ years of experience in enterprise network administration.
- Proficiency in managing firewall and VPN appliances.
- Strong grasp of security best practices in cloud and hybrid environments.
- Experience with scripting and automation tools (e.g., PowerShell, Python).
- Strong troubleshooting and documentation skills.

Why Join Us:

- Work with a mission-driven team in a secure and innovative environment.
- Hybrid work environment with strong support for remote collaboration.

What should **not** be in either version?

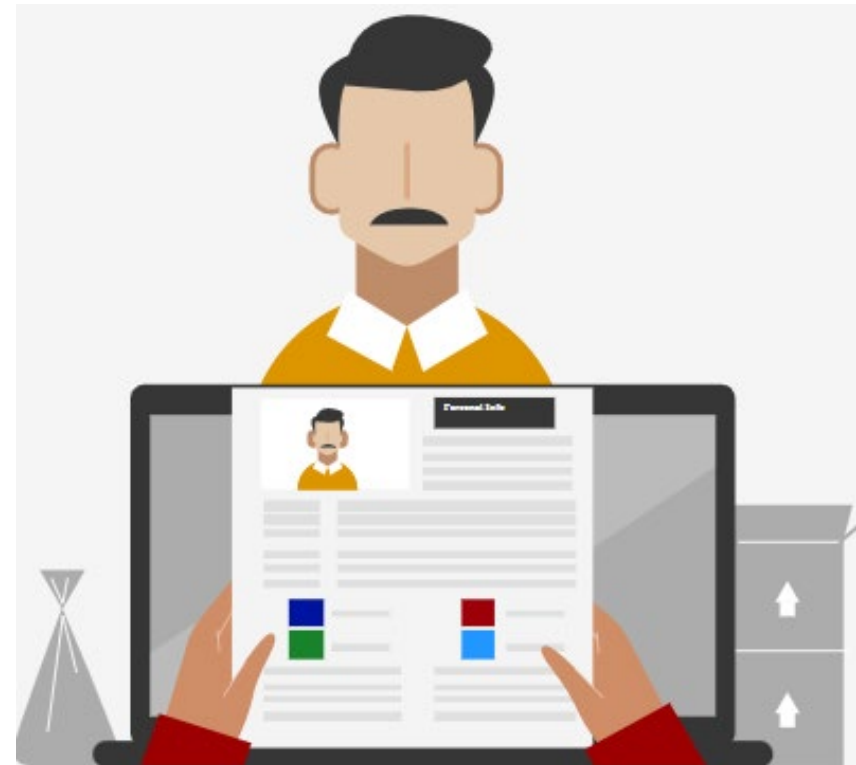
- Neither version of the job description should include information regarding:
 - specific systems,
 - software versions,
 - security configurations,
 - or access controls.



v2.0.20

Candidate Application Data

- Companies are responsible for protecting the data and privacy of the job seeker
- Nonpublic personal information (NPPI) should not be collected if possible



<https://www.f-secure.com/>

The Interview

- A job interview is a perfect **foot-printing** opportunity for hackers and social engineers
- The interviewer should be concerned about revealing too much about the company during the interview
- Job candidates should never gain access to secured areas



Image copyrighted to cengage/pearson for Principles of Incident Response and Disaster Recovery, by Whitman, Mattord, & Green

In Practice

Job Recruitment Policy

Synopsis: In support of cybersecurity, the purpose of this policy is to ensure that company and candidate resources are protected during the recruitment process.

Policy Statement:

- Any information that is classified as “protected” or “confidential” must not be included in job postings or job descriptions.
- Candidates will not be allowed access to any secure area unless authorized in writing by the information owner.
- All nonpublic information submitted by candidates must be classified as “protected” and handled in accordance with company handling standards.
- Under no circumstances will the company request that candidates provide a password to social media, blog, web, or personal email accounts.
- The Office of Information Security and the Office of Human Resources will be jointly responsible for the implementation and enforcement of this policy.

Screening Prospective Employees–Scenario 1

- You are a business owner. You have spent the past 10 years working night and day to build your business.
- You have invested your personal financial resources.
- Your reputation in the community is intertwined with the actions of the business.
- **Question:** How much do you need to know about your newest salesperson?



<https://salestalentinc.com/>

Screening Prospective Employees–Scenario 2

- You are the Chief Executive Officer (CEO) of a Fortune 1000 financial services company.
- You are responsible to the stockholders and accountable to the government for the actions of your business.
- **Question:** How much do you need to know about your new Chief Financial Officer (CFO)?



Screening Prospective Employees–Scenario 3

- You are the Head of Medicine at your local hospital.
- You are responsible for maintaining the health of your patients and for guaranteeing their right to privacy.
- **Question:** How much do you need to know about the new emergency room intake nurse?



Screening Prospective Employees /1

- In all three cases, the information owner wants assurance that the user (e.g., employee) will treat the information appropriately in accordance with its classification.
- Define the user criteria: education, experience, certification/license, criminal record, and financial status.



Screening Prospective Employees /2

- An organization should protect itself by running extensive **background checks** on potential employees at all levels of the hierarchy
- Some higher-level positions may require even more in-depth checks
- Many government jobs require prospective employees have the requisite clearance level

 Government of Canada / Gouvernement du Canada

[Français](#)

Search Canada.ca 

MENU ▾

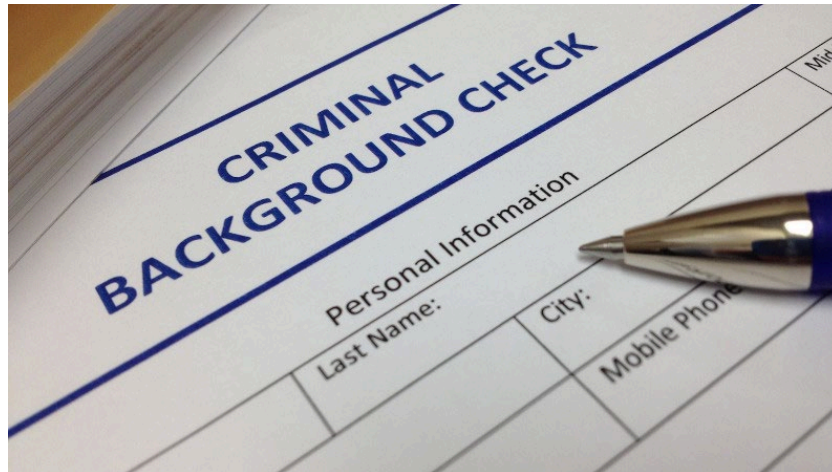
[Canada.ca](#) > [Office of the Superintendent of Bankruptcy](#) > [Bankruptcy and Insolvency Records Search](#)

Bankruptcy and Insolvency Records Search

A [minimum fee of \\$8 per search](#) is charged to search the Bankruptcy and Insolvency Records database, except for *Companies' Creditors Arrangement Act* (CCAA) Records, which may be consulted free of charge. You may pay by credit card or, if you plan to use the service regularly, you may [open an account with the Office of the Superintendent of Bankruptcy](#).

Background Checks

- All employees should be subject to a basic background check
- Information owners may require more in-depth checks for specific roles
- ~~Workers~~ have a right to privacy; gather only information relevant to the work they perform
- Seek consent from employees before launching a background check



~~Types of Background Checks~~

- The various types of background checks are as follows:
 - ~~Educational~~
 - ~~Employment~~
 - ~~License/certification~~
 - ~~Credit history~~
 - ~~Criminal history~~

Government Clearance

- Each government agency has its own standards.
- In general, a security clearance investigation is an inquiry into an individual's **loyalty, character, trustworthiness**, and **reliability** to ensure that he or she is eligible for access to national security-related information.

The screenshot shows the top portion of the 'SECURITY CLEARANCE FORM' (Form 330-60-nf-eng.pdf) from the Government of Canada. The form is marked 'PROTECTED (When completed)'. It includes a header with the Government of Canada logo and name in both English and French. Below this is a table for 'OFFICE USE ONLY' with columns for Reference number, Department number, and File number. The main body of the form is divided into sections: A. ADMINISTRATIVE INFORMATION (To be completed by Department/Agency/Organization), B. BIOGRAPHICAL INFORMATION (To be completed by the applicant), C. SECURITY SCREENING, and D. MARITAL STATUS/Common-Law Partnership. Each section contains various fields for personal and organizational information, such as name, date of birth, sex, and marital status. The form is currently blank, showing only the headers and section titles.

<https://www.tbs-sct.canada.ca/tbsf-fsct/330-60-nf-eng.pdf>

Government Clearance

- The process to obtain clearance is both costly and time-consuming, and involves:
 - Application phase
 - Investigative phase
 - Adjudication phase
 - Granting (or denial) of clearance at a specific level

Requesting a security clearance

Only a CSO or ACSO may request a security clearance for an individual on behalf of an organization registered in the CSP.

Visit [who is eligible for a personnel security screening](#) and [accepted justification to process personnel security screening requests](#) for more information on an individual's eligibility for personnel security screening.

To request a **new** security clearance, or to **update** or **upgrade** an existing security clearance, the CSO or ACSO and the employee must complete and submit the following forms:

- [Personnel screening, consent and authorization form \(TBS/SCT 330-23E\)](#)
- [Security clearance form \(TBS/SCT 330-60E\)](#)

Processing times for a security clearance depend on the [complexity of the request](#) and the verifications that must be completed. Requests can be categorized as either simple or complex. For more information, visit [cost and processing times for personnel security screenings](#).

The CSO or ACSO can only submit their personnel security screening request to the CSP once they have completed and documented a thorough verification of the applicant's security form and background.

Learn how to [complete the security clearance forms](#) and how to [obtain the status of a personnel security screening application](#).

Information needed

The following will be **requested**:

- a law enforcement inquiry by the Royal Canadian Mounted Police through
 - [mandatory electronic fingerprints](#)

<https://www.canada.ca/>

In Practice

Personnel Screening Policy

Synopsis: Background checks must be conducted on employees, temporaries, and contractors.

Policy Statement:

- As a condition of employment, all employees, temporaries, and contractors must agree to and are subject to background screening that includes identity verification, confirmation of educational and professional credentials, credit check, and state and federal criminal check.
- Comprehensive background screening will be conducted pre-hire. Criminal check will be conducted annually thereafter.
- Background screening will be conducted in accordance with local, state, and federal law and regulations.
- If the person will have access to “protected” or highly confidential information, additional screening may be required at the discretion of the information owner. This includes new personnel as well as employees who might be moved into such a position.
- Background screening will be conducted and/or managed by the Human Resources department.

What Happens in the Onboarding Phase?

- The new hire is added to the organization's payroll and benefit systems
- New employees must provide
 - Proof of identity
 - Work authorization
 - Tax identification

Canada Revenue Agency / Agence du revenu du Canada

2026 Personal Tax Credits Return

Read page 2 before filling out this form. Your employer or payer will use this form to determine the amount of your tax deductions.

Fill out this form based on the best estimate of your circumstances.

If you do not fill out this form, your tax deductions will only include the basic personal amount, estimated by your employer or payer based on the income they pay you.

Last name, First name and initial(s), Date of birth (YYYY/MM/DD), Employee number, Address, Postal code, For non-residents only Country of permanent residence, Social insurance number

1. Basic personal amount – Every resident of Canada can enter a basic personal amount of \$16,452. However, if your net income from all sources will be greater than \$181,440 and you enter \$16,452, you may have an amount owing on your income tax and benefit return at the end of the tax year. If your income from all sources will be greater than \$181,440 you have the option to calculate a partial claim. To do so, fill in the appropriate section of Form TD1-WS, Worksheet for the 2026 Personal Tax Credits Return, and enter the calculated amount here.

2. Canada caregiver amount for infirm children under age 18 – Only one parent may claim \$2,740 for each infirm child born in 2009 or later who lives with both parents throughout the year. If the child does not live with both parents throughout the year, the parent who has the right to claim the "Amount for an eligible dependant" on line 8 may also claim the Canada caregiver amount for the child.

3. Age amount – If you will be 65 or older on December 31, 2026, and your net income for the year from all sources will be \$46,432 or less, enter \$9,208. You may enter a partial amount if your net income for the year will be between \$46,432 and \$107,819. To calculate a partial amount, fill out the line 3 section of Form TD1-WS.

4. Pension income amount – If you will receive regular pension payments from a pension plan or fund (not including Canada Pension Plan, Quebec Pension Plan, old age security, or guaranteed income supplement payments), enter whichever is less: \$2,000 or your estimated annual pension income.

5. Tuition (full-time and part-time) – Fill in this section if you are a student at a university or college, or an educational institution certified by Employment and Social Development Canada, and you will pay more than \$100 per institution in tuition fees. Enter the total tuition fees that you will pay if you are a full-time or part-time student.

6. Disability amount – If you will claim the disability amount on your income tax and benefit return by using Form T2201, Disability Tax Credit Certificate, enter \$10,341.

7. Spouse or common-law partner amount – Enter the difference between the amount on line 1 (line 1 plus \$2,740 if your spouse or common-law partner is infirm) and your spouse's or common-law partner's estimated net income for the year if two of the following conditions apply:

- You are supporting your spouse or common-law partner who lives with you
- Your spouse or common-law partner's net income for the year will be less than the amount on line 1 (line 1 plus \$2,740 if your spouse or common-law partner is infirm)

In all cases, go to line 9 if your spouse or common-law partner is infirm and has a net income for the year of \$29,374 or less.

8. Amount for an eligible dependant – Enter the difference between the amount on line 1 (line 1 plus \$2,740 if your eligible dependant is infirm) and your eligible dependant's estimated net income for the year if all of the following conditions apply:

- You do not have a spouse or common-law partner, or you have a spouse or common-law partner who does not live with you and who you are not supporting or being supported by
- You are supporting the dependant who is related to you and lives with you
- The dependant's net income for the year will be less than the amount on line 1 (line 1 plus \$2,740 if your dependant is infirm and you cannot claim the Canada caregiver amount for infirm children under 18 years of age for this dependant)

In all cases, go to line 9 if your dependant is 18 years or older, infirm, and has a net income for the year of \$29,374 or less.

TD1 2026 Personal Tax Credits Return

User Provisioning Policy

- User provisioning is the process of:
 - Creating user accounts and group memberships
 - Providing company identification
 - Assigning access rights and permissions
 - Assigning access devices such as tokens and/or smartcards

- The user should be **provided with** and **acknowledge** the terms and conditions of the acceptable use agreement before being granted access

Technology Use Policy

Classification number	LCG 1109
Framework category	Legal, Compliance and Governance
Approving authority	Board of Governors
Policy owner	Vice-President, Administration
Approval date	April 23, 2020
Review date	March 2023
Last updated	Editorial Amendment, October 14, 2025
Supersedes	Policy on Acceptable Use of Information Technology, March 2006; May 2012; Editorial Amendments, February 18, 2020

Purpose

1. The University owns, maintains and manages Information Technology (IT) resources to support the educational, instructional and research activities of the University.
2. While University Members are free to use these valuable resources in pursuit of their individual and collective academic and research activities, safeguards are in place to ensure that the information, equipment and networks remain compliant, reliable, robust and secure.
3. This Policy sets out the acceptable and responsible use of IT Resources in a manner that is consistent with the University's values, accountability, and intellectual rigour.
4. Before University Members can access or use the University's IT Resources, University Members must:
 - 4.1 review this Policy or a terms of use that fully complies with this policy, as well as other policies applicable to the type of use.
 - 4.2 accept the University's terms and conditions of use.

Definitions

In Practice

User Provisioning Policy

Synopsis: The company must have an enterprise-wide user provisioning process.

Policy Statement:

There will be defined and documented a user provisioning process for granting and revoking access to information resources that includes but is not limited to account creation, account management (including assignment of access rights and permissions), periodic review of access rights and permissions, and account termination.

The Office of Human Resources and the Office of Information or Cybersecurity are jointly responsible for the user provisioning process.

What Should an Employee Learn During Orientation?

- The employee should learn what his or her responsibilities will be
- The employee should receive instruction about information handling standards and **privacy protocols**
- The employee should have the opportunity to ask questions



Why Is Termination Considered The Most Dangerous Phase?

- Emotionally charged event
 - Terminated employee may seek revenge, create havoc, or take information
- Where there is any concern that the employee may react negatively, all access to data and systems should be disabled prior to informing the employee



<https://tandemhr.com/>

In Practice

Employee Termination Policy

Synopsis: Information assets and systems must be protected from terminated employees.

Policy Statement:

- Upon the termination of the relationship between the company and any employee, all access to facilities and information resources shall cease.
- In the case of unfriendly termination, all physical and technical access will be disabled pre-notification.
- In the case of a friendly termination, including retirement, the Office of Human Resources is responsible for determining the schedule for disabling access.
- Termination procedures are to be included in the user provisioning process.
- The Office of Human Resources and the Office of Information or Cybersecurity are jointly responsible for the user provisioning process.

Topics

- Employee Life Cycle
- Employee Agreements
- Security Education and Training Awareness (SETA)

The Importance of Employer Agreements

- It is common practice to require employees, contractors, and outsourcers to sign two basic agreements:

1. A **confidentiality agreement** (also known as a nondisclosure agreement).

2. An **acceptable use agreement**.

Your Non-Disclosure Agreement

- j. 'Proprietary Computer Code' which includes all sets of statements, instructions or programs of the Employer, whether in human readable or machine readable form, that are expressed, fixed, embodied or stored in any manner and that can be used directly or indirectly in a computer ('Computer Programs'); any report format, design or drawing created or produced by such Computer Programs; and all documentation, design specifications and charts, and operating procedures which support the Computer Programs; and
- k. Confidential Information will also include any information that has been disclosed by a third party to the Employer and is protected by a non-disclosure agreement entered into between the third party and the Employer.
4. Confidential Information will not include the following information:
- a. Information that is generally known in the industry of the Employer;
 - b. Information that is now or subsequently becomes generally available to the public through no wrongful act of the Employee;
 - c. Information rightly in the possession of the Employee prior to the disclosure to the Employee by the Employer;
 - d. Information that is independently created by the Employee without direct or indirect use of the Confidential Information; or
 - e. Information that the Employee rightfully obtains from a third party who has the right to transfer or disclose it.
- Obligations of Non-Disclosure**
5. Except as otherwise provided in this Agreement, the Employee must not disclose the Confidential Information.
6. Except as otherwise provided in this Agreement, the Confidential Information will remain the exclusive property of the Employer and will only be used by the Employee for the Permitted Purpose. The Employee will not use the Confidential Information for any purpose that might be directly or indirectly detrimental to the Employer or any associated affiliates or

<https://www.lawdepot.ca/contracts/non-disclosure-agreement/>

1- Confidentiality or Non-Disclosure Agreements

- Agreement between employees and the organization
- Defines what information may not be disclosed by employees
- **Goal: To protect sensitive information**
- Especially important in these situations:
 - When an employee is terminated or leaves
 - When a third-party contractor was employed

2- Acceptable Use Agreements

- A policy contract between the company and information systems user
- Components of an Acceptable Use Agreement
 - Introduction
 - Data classifications
 - Applicable policy statement
 - Handling standards
 - Contacts
 - Sanctions for violations
 - Acknowledgment

In Practice

Employee Agreements Policy

Synopsis: All employees and third-party personnel not otherwise covered by contractual agreement are required to agree to Confidentiality and Acceptable Use requirements.

Policy Statement:

- All employees must be provided with and sign a confidentiality agreement as a condition of employment and prior to being provided any company information classified as protected, confidential, or internal use.
- All employees must be provided with and sign an acceptable use agreement as a condition of employment and prior to being granted access to any company information or systems.
- The documents provided to the employee will clearly state the employees' responsibilities during both employment and post-employment.
- ~~The~~ employee's legal rights and responsibilities will be included in the document.
- Legal counsel is responsible for developing, maintaining, and updating the confidentiality agreement.
- The Office of Information or Cybersecurity is responsible for developing, maintaining, and updating the acceptable use agreement.
- The Office of Human Resources is responsible for distributing the agreement and managing the acknowledgment process.

Topics

- Employee Life Cycle
- Employee Agreements
- Security Education and Training Awareness (SETA)

Security Education and Training /1

- According to NIST SP800-50: “Federal agencies [...] **cannot protect** [...] information [...] **without ensuring that all people involved** [...]:
 - Understand their role and responsibilities related to the organization’s mission
 - Understand the organization’s IT security policy, procedures, and practices
 - ~~Have~~ at least adequate knowledge of the various management, operational, and technical controls required and available to protect the IT resources for which they are responsible”



~~Security~~ Education and Training /2

- Only securing network devices and neglecting to train users on cybersecurity topics is ignoring half of the threats against the company
- Workers must be trained to identify and defend against social engineering attacks
 - It is often easier to use social engineering rather than hack a network device



Security Education and Training /3

- Security training “seeks to teach skills” (per NIST)
- All employees should receive security training



What Is the SETA Model?

- SETA: Security Education Training and Awareness
- Awareness is not training; It is focusing the attention of employees on security topics to change their behaviour
- Security awareness campaigns should be scheduled regularly

Education	Training	Awareness
What	How	Why
Knowledge	Skills	Understanding

Topics

- Employee Life Cycle
- Employee Agreements
- Security Education and Training Awareness (SETA)

Summary

- Personnel security must be integrated across the entire employee lifecycle, from recruitment to termination. Organizations should demonstrate a strong security culture early and ensure protection of sensitive candidate and employee data.
- Pre-employment background checks (criminal, credit, licensure) are important but must comply with legal and privacy constraints. Employers must obtain consent and adhere to regulations governing what information can be used in hiring decisions.
- Certain roles (e.g., government positions) require security clearances involving deeper evaluation of trustworthiness and reliability. Confidentiality agreements are essential and legally define how sensitive information may be handled and disclosed.
- Acceptable use agreements outline policies, data handling, monitoring, and consequences of misuse. Ongoing security awareness, training, and education reinforce secure behavior and informed decision-making throughout employment.
- Employee termination poses security risks and must be handled cautiously by promptly revoking all access. HR security policies cover the full lifecycle, including hiring, monitoring, training, and termination.